

Lab - Investigating OWASP

Objectives

Part 1: OWASP Top 10

Part 2: OWASP Community Pages

Background / Scenario

[Open Web Application Security Project \(OWASP\)](https://owasp.org/) is a non-profit organization that is dedicated to web application security. OWASP publishes a list of the Top 10 most critical web security concerns facing organizations about every three years. The objective of this report is to raise awareness regarding web application security and to help organizations incorporate this information into their process to minimize and mitigate security risks.

OWASP also accepts community contributions for security related content. The [OWASP Community Pages](https://owasp.org/www-community/) provides list of attacks and vulnerabilities reported by the communities.

In this lab, you will explore the OWASP Top 10 from 2021 and a few of the attacks and vulnerabilities reported by community contributors.

Required Resources

= Internet access

Instructions

Part 1: OWASP Top 10

- Navigate to the OWASP Top 10 (<https://owasp.org/Top10>).
- At the time of this writing, the draft of latest list of Top 10 was published in 2021.

Review the Top 10 categories. Pick 3 categories out of the Top 10. In the table below, list your chosen categories. Then briefly describe the category and some of the ways to prevent attacks in the category.

Top 10 Category	Description	Prevention
Injection	An application flaw that allows untrusted user input to be sent to an interpreter and causes the interpreter to execute parts of that input as commands.	The preferred option is to use a safe API, which avoids using the interpreter entirely, provides a parameterized interface, or migrates to Object Relational Mapping Tools.
Insecure Design	A broad category representing different weaknesses, expressed as “missing or ineffective control design.	Establish and use a secure development lifecycle with AppSec professionals to help evaluate and design security and privacy-related controls.

Top 10 Category	Description	Prevention
Security Misconfiguration	When a system, application, or cloud service is set up incorrectly from a security perspective, creating vulnerabilities.	Implementing a repeatable hardening process enabling the fast and easy deployment of another environment that is appropriately locked down.

Part 2: OWASP Community Pages

The OWASP Community Pages allows security-related contributions from the community. In this part, you will review the Vulnerabilities pages to investigate the attack techniques reported by the contributors.

- a. Navigate to the OWASP Community Page for Vulnerabilities. (<https://owasp.org/www-community/vulnerabilities/>).

OWASP defines a vulnerability as flaw in the application that a threat actor can exploit.

Review the List of Vulnerabilities and pick 3. In the table below, list your chosen vulnerabilities. Briefly describe the vulnerability and some of the ways to prevent exploitation.

Vulnerabilities	Description	Prevention
Buffer Overflow	Exists when a program attempts to put more data in a buffer than it can hold or when a program attempts to put data in a memory area past a buffer.	Apply the latest patches, keep up with the latest bug reports for web and application server products and other products within you're internet infrastructure.
Covert storage channel	Occurs when out-of-band data is stored in messages for the purpose of memory reuse.	Ensure that all reserved fields are set to zero before messages are sent and that no unnecessary information is included.
Improper Data Validation	When validation forms with the same name indicate that validation logic is not up-to-date.	Use Struts Validator to check all program input before it is processed by the application.

- b. Navigate to the OWASP Community Page for Attacks. (<https://owasp.org/www-community/attacks>).

According to OWASP, an attack is a technique used to exploit application vulnerabilities.

Review the **List of Attacks** and pick 3. In the table below, list your chosen attacks. Then briefly describe the attack and some of the ways to prevent it.

Attacks	Description	Prevention
Brute Force Attack	Can manifest itself in many different ways, but primarily consists in an attacker configuring predetermined values, making requests to a server using those values, and then analyzing the response.	Detect your web servers being scanned by brute force tools such as, Wfuzz, OWASP Dirbuster and vulnerability scanners such as Nessus, Nikto, Acunetix, etc. This helps you quickly identify probable probing by bad actors who want to dig possible security holes.
Click Jacking	When attacker uses multiple transparent or opaque layers to trick a user into clicking on a button or link on another page when they are intending to click on the top level page.	Employing defensive code in the UI to ensure that the current frame is the most top level window.
Command Injection	An attack in which the goal is execution of arbitrary commands on the host operation system via a vulnerable application.	Developer should use existing API for their language.